

PENTEST REPORT

Reconnaissance and Vulnerability Analysis

Target: 10.129.95.233
Generated: 04/06/2026 22:38 · NmapRAG Engine

1	5	1	2	1
Open Ports	Vulnerabilities	Critical	High	Sessions

Report Contents

1	Executive Summary
2	Confirmed Attack Vectors
3	Ports and Services
4	Web Fuzzing Findings (ffuf)
5	CVE Vulnerabilities — Full Detail
6	Metasploit Exploitation Results
7	Execution Timing
8	Execution Log

1. Executive Summary

Attack Surface Summary

The attack surface is **HIGH** due to the presence of multiple potentially risky HTTP methods (TRACE, COPY, PROPFIND, SEARCH, LOCK, UNLOCK, DELETE, PUT) and WebDAV features detected on port 80, which is running Microsoft IIS 6.0. This outdated server version is known to be insecure and may be vulnerable to remote code execution (RCE) or other exploits. The presence of WebDAV with multiple allowed methods increases the risk of exploitation, especially since no authentication restrictions were indicated.

Detected Services and Versions

- **Port 80:** Microsoft IIS httpd 6.0
 - Service name: Microsoft IIS httpd
 - Version: 6.0
-

Key Findings

- **Potentially risky HTTP methods** detected: TRACE, COPY, PROPFIND, SEARCH, LOCK, UNLOCK, DELETE, PUT.
 - **WebDAV features** detected with multiple allowed methods, which can be exploited for unauthorized file operations.
 - **Microsoft IIS 6.0** is an outdated and insecure web server version.
 - **HTTP server title** indicates the site is under construction, which may imply less security hardening.
 - **No open UDP ports** found in the top 100 most common UDP ports.
 - **WebDAV OPTIONS** response shows allowed methods, including potentially dangerous ones like PROPFIND, COPY, and DELETE.
 - **No authentication restrictions** were indicated for the detected services.
-

Recommended Next Steps

1. Check for known vulnerabilities in Microsoft IIS 6.0:

- CVE-2006-4132 (IIS 6.0 remote code execution via malformed HTTP request)
- CVE-2002-0443 (IIS 6.0 buffer overflow in ISAPI extension)
- CVE-2001-1148 (IIS 6.0 buffer overflow in ASP processing)

2. Test for WebDAV vulnerabilities:

- Use Metasploit module: `exploit/multi/http/webdav_lock`

- Use Metasploit module: `exploit/multi/http/webdav_propfind`
- Use Metasploit module: `exploit/multi/http/webdav_copy`

3. Test for IIS 6.0 remote code execution:

- Use Metasploit module: `exploit/windows/http/iis6_iusreset`
- Use Metasploit module: `exploit/windows/http/iis6_iscsi`

4. Verify if authentication is required for WebDAV operations:

- Use `curl` or `wget` with basic authentication to test access to restricted directories like `/private` or `/vti_pvt`.

5. Scan for additional vulnerabilities:

- Run `nmap --script http-vuln* -p 80 10.129.95.233` to detect known HTTP vulnerabilities.

6. Ensure firewall rules are updated to block unnecessary HTTP methods (e.g., DELETE, PROPFIND, COPY) and restrict access to WebDAV endpoints.

7. Upgrade IIS to a supported version to mitigate known vulnerabilities and improve security posture.

2. Confirmed Attack Vectors

3 known vulnerabilities identified by automatic correlation of detected service versions against the exploit knowledge base. These vectors are **confirmed** by exact service version and do not depend on LLM analysis.

[CRITICAL] WebDAV with multiple allowed methods
(including PUT/DELETE)

Port: 80 · **Service:** microsoft Microsoft IIS httpd 6.0

[HIGH] Remote Code Execution in Microsoft IIS 6.0

CVE-2010-1256

Port: 80 · **Service:** microsoft Microsoft IIS httpd 6.0

[MEDIUM] Directory Traversal Vulnerability in Microsoft
IIS 6.0

CVE-2005-2089

Port: 80 · **Service:** microsoft Microsoft IIS httpd 6.0

3. Ports and Services Detected

1 open port(s) detected on target.

Port	Service	Version	Proto	Notes
80	Microsoft	IIS httpd 6.0	TCP	■ Sensitive service

4. Web Fuzzing Findings (ffuf)

17 paths discovered via directory fuzzing. Findings are listed below with associated risk analysis.

Paths with identified risk

Severity	URL / Path	Status	Risk Description
High	<code>http://10.129.95.233/_vti_bin/_vti_adm/admin.dll</code>	200	Administration panel exposed. Test default credentials and brute-force.

Critical and High findings detail

[HIGH] `http://10.129.95.233/_vti_bin/_vti_adm/admin.dll`

Administration panel exposed. Test default credentials and brute-force.

Other discovered paths (16)

The following paths have no predefined risk pattern but should be reviewed manually for undocumented functionality.

- `http://10.129.95.233/` [200] 1433 bytes
- `http://10.129.95.233/_private` [403] 1529 bytes
- `http://10.129.95.233/_vti_cnf` [403] 1529 bytes
- `http://10.129.95.233/_vti_bin` [301] 157 bytes
- `http://10.129.95.233/_vti_log` [403] 1529 bytes
- `http://10.129.95.233/_vti_pvt` [403] 1529 bytes
- `http://10.129.95.233/_vti_txt` [403] 1529 bytes
- `http://10.129.95.233/_vti_bin/_vti_aut/author.dll` [200] 195 bytes
- `http://10.129.95.233/_vti_bin/shtml.dll` [200] 96 bytes
- `http://10.129.95.233/aspnet_client` [403] 218 bytes
- `http://10.129.95.233/images` [301] 151 bytes
- `http://10.129.95.233/Images` [301] 151 bytes
- `http://10.129.95.233/_vti_bin/` [403] 218 bytes
- `http://10.129.95.233/_vti_bin/_vti_aut` [301] 170 bytes
- `http://10.129.95.233/images/` [403] 218 bytes
- `http://10.129.95.233/Images/` [403] 218 bytes

5. CVE Vulnerabilities — Full Detail

2 CVE(s) identified across exposed services (1 from NVD · 0 from knowledge base).

Severity	Count	Typical Impact
HIGH	1	Privilege escalation, unauthorised data access
MEDIUM	1	Denial of service, partial information disclosure

Port 80 — Microsoft IIS httpd 6.0

[HIGH] CVE-2010-1256

8.5

Unspecified vulnerability in Microsoft IIS 6.0, 7.0, and 7.5, when Extended Protection for Authentication is enabled, allows remote authenticated users to execute arbitrary code via unknown vectors related to "token checking" that trigger memory corruption, aka "IIS Authentication Memory Corruption Vulnerability."

Published	2010-06-08
CVSS Vector	AV:N/AC:M/Au:S/C:C/I:C/A:C
Attack Vector	NETWORK
CWE	CWE-94

Exploitation context:

Remotely exploitable — no physical access or local presence required.

References:

securityfocus.com
us-cert.gov
[Microsoft](https://microsoft.com)
[NVD](https://nvd.nist.gov)

[MEDIUM] CVE-2005-2089**4.3**

Microsoft IIS 5.0 and 6.0 allows remote attackers to poison the web cache, bypass web application firewall protection, and conduct XSS attacks via an HTTP request with both a "Transfer-Encoding: chunked" header and a Content-Length header, which causes IIS to incorrectly handle and forward the body of the request in a way that causes the receiving server to process it as a separate HTTP request, aka "HTTP Request Smuggling."

Published	2005-07-05
CVSS Vector	AV:N/AC:M/Au:N/C:N/I:P/A:N
Attack Vector	NETWORK
CWE	CWE-444

Exploitation context:

Remotely exploitable — no physical access or local presence required.

References:

seclists.org
securiteam.com
watchfire.com
NVD

6. Metasploit Exploitation Results

2 module(s) executed · 1 vulnerable · 1 session(s) opened · 0 error(s)

Execution Plan

#	CVE	CVSS	Module	Result
1	CVE-2017-7269	9.0	exploit/windows/iis/iis_webdav_scstoragepath fromurl	SESSION

SESSION OPENED

7. Execution Timing

Total scan duration: **14m 13s** (853.7s)

Phase	Duration	% of Total
Model warm-up	1m 07s	7.9%
Phase 0 — TCP Discovery	1m 55s	13.5%
Phase 1 — Version Detection	35s	4.1%
Phase 2 — Adaptive NSE	1m 46s	12.5%
Phase 3 — Firewall Detection	6s	0.7%
Phase 4 — UDP Scan	45s	5.3%
Phase 5 — Web Fuzzing	2m 37s	18.4%
Phase 6 — Metasploit	4m 03s	28.5%
Phase 7 — Searchsploit + Creds	1s	0.2%
Total	14m 13s	100%

8. Execution Log

15 step(s) executed during reconnaissance.

✓ Step 1 — Full TCP SYN scan (all 65535 ports)

```
nmap -Pn -sS -p- --min-rate 1000 --max-retries 2 10.129.95.233
```

→ Found: 80 (http)

✓ Step 2 — Version + OS detection on 80

```
nmap -Pn -sV -O --version-intensity 5 -sC --script-timeout 60s -p 80 -oX /home/marina/Desktop/pentestM/RAG/outputs/nmap_sV_10_129_95_233.xml 10.129.95.233
```

→ Found: 80 (Microsoft IIS httpd 6.0)

→ Potentially risky HTTP methods detected: TRACE, COPY, PROPFIND, SEARCH, LOCK, UNLOCK, DELETE, PUT

→ WebDAV features detected with multiple allowed methods

✓ Step 3 — Check for Shellshock Vulnerability

```
nmap -Pn -sV --script http-shellshock -p 80 10.129.95.233 --script-timeout 30s
```

→ Found: 80 (Microsoft IIS httpd 6.0)

✓ Step 4 — Find Authentication Methods

```
nmap -Pn -sV --script http-auth-finder -p 80 10.129.95.233 --script-timeout 30s
```

→ Found: 80 (Microsoft IIS httpd 6.0)

✓ Step 5 — Check for HTTP Title

```
nmap -Pn -sV --script http-title -p 80 10.129.95.233 --script-timeout 30s
```

→ Found: 80 (Microsoft IIS httpd 6.0)

→ HTTP server title indicates the site is under construction

→ Microsoft IIS 6.0 is an outdated and potentially insecure web server version

✓ Step 6 — ACK scan — firewall detection

```
nmap -Pn -sA -p 80 10.129.95.233
```

✓ Step 7 — UDP scan — top 100 ports by frequency

```
nmap -Pn -sU --top-ports 100 --open --max-retries 1 10.129.95.233
```

→ No open UDP ports found in the top 100 most common UDP ports.

✓ Step 8 — UDP scan — exploit-focused service ports

```
nmap -Pn -sU -p 53,67,69,111,123,137,138,161,162,500,623,1434,1900,4500,5353,11211,17185 --open --max-retries 1 10.129.95.233
```

✓ Step 9 — ffuf — http://10.129.95.233

```
ffuf -u http://10.129.95.233/FUZZ -w /usr/share/dirb/wordlists/common.txt -t 40 -v -timeout 10 -e php,html,txt,js,json,bak,old,zip -o /tmp/ffuf_output_1780605058.json -of json -fs 1635
```

- [200] http://10.129.95.233/
- [403] http://10.129.95.233/_private
- [403] http://10.129.95.233/_vti_cnf
- [301] http://10.129.95.233/_vti_bin
- [403] http://10.129.95.233/_vti_log

✓ Step 10 — ffuf — http://10.129.95.233/_vti_bin/

```
ffuf -u http://10.129.95.233/_vti_bin/FUZZ -w /usr/share/dirb/wordlists/common.txt -t 40 -v -timeout 10 -e php,html,txt,js,json,bak,old,zip -o /tmp/ffuf_output_1780605096.json -of json -fs 1635
```

- [403] http://10.129.95.233/_vti_bin/
- [301] http://10.129.95.233/_vti_bin/_vti_aut

✓ Step 11 — ffuf — http://10.129.95.233/images/

```
ffuf -u http://10.129.95.233/images/FUZZ -w /usr/share/dirb/wordlists/common.txt -t 40 -v -timeout 10 -e php,html,txt,js,json,bak,old,zip -o /tmp/ffuf_output_1780605134.json -of json -fs 1635
```

- [403] http://10.129.95.233/images/

✓ Step 12 — ffuf — http://10.129.95.233/Images/

```
ffuf -u http://10.129.95.233/Images/FUZZ -w /usr/share/dirb/wordlists/common.txt -t 40 -v -timeout 10 -e php,html,txt,js,json,bak,old,zip -o /tmp/ffuf_output_1780605172.json -of json -fs 1635
```

- [403] http://10.129.95.233/Images/

✓ Step 13 — ffuf vhosts — FUZZ.10.129.95.233

```
ffuf -u http://10.129.95.233 -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt -t 40 -H 'Host: FUZZ.10.129.95.233' -o /tmp/ffuf_vhost_80_1780605210.json -of json -v -ac
```

✓ Step 15 — MSF exploitation phase

```
msfconsole (multiple modules)
```

✗ Step 15 — Searchsploit + credential phase

```
searchsploit / paramiko / ftplib
```